

Fundación Politécnico Minuto de Dios

MONITOREO Y GESTIÓN DE LA SEGURIDAD

Diagnóstico, Gobernanza e Indicadores Tecnológicos en
Entornos Híbridos

Materia: Implementación de bases de datos

Estudiante: Miguel Angel Peralta Cano

Docente: José Luis Rodriguez Cortes

Caso de Estudio: Sweet Tees & more

21 de junio de 2026

Resumen

En este informe presentaré mi propuesta analítica y técnica sobre la gestión integral de ciberseguridad del ecosistema informático de Sweet Tees & more. En respuesta a su dramática transición de un modelo analógico de serigrafía hacia una producción de transferencias digitales B2C de alto rendimiento, la empresa enfrentó la necesidad imperiosa de resguardar activos críticos. A lo largo del documento detallaré en profundidad la topología de la red de área local y extensa (LAN/WAN), el despliegue del Sistema Gestor de Bases de Datos (PostgreSQL en la nube), el marco operativo del personal de soporte técnico (SOC/NOC)

y las políticas estrictas de control de acceso (RBAC). Asimismo, presentaré una matriz de evaluación de riesgos exhaustiva y desarrolla un catálogo técnico con once indicadores de gestión críticos, cuyo fin no es meramente informar, sino actuar como pilares defensivos contra inyecciones SQL, ransomware, degradación de disponibilidad y exfiltración masiva de propiedad intelectual corporativa y datos personales de clientes.

Índice

1. Introducción y Análisis de la Transformación Digital	4
2. Arquitectura de Hardware y Red (Ecosistema Híbrido)	4
2.1. Perímetro y Core Networking	4
2.2. Infraestructura de Endpoints y Servidores Locales	5
3. Ecosistema de Bases de Datos y Nube (Cloud Storage)	5
3.1. Sistema Gestor de Base de Datos (SGBD)	5
3.2. Almacenamiento de Archivos e Inmutabilidad	5
4. Gobernanza de Seguridad: Modelos de Acceso y SOC	6
4.1. Organigrama Operativo y Roles Clave	6
4.2. El Factor Humano: Centro de Soporte y Respuesta	7
4.3. Control de Acceso Basado en Roles (RBAC)	7
5. Catálogo Exhaustivo de Evaluación de Riesgos	7
6. Libro Maestro de Indicadores de Gestión Tecnológica	9
6.1. 1. Tasa de Intentos de Acceso Fallidos al E-Commerce (TIAF)	9
6.2. 2. Porcentaje de Éxito en Respaldos del Catálogo (PERC)	9
6.3. 3. Alertas de Robo de Propiedad Intelectual (IAED)	10
6.4. 4. Tiempo Medio de Instalación de Parches (TMIP)	10
6.5. 5. Disponibilidad del Sistema y Enlaces Concurrentes (Uptime)	11
6.6. 6. Tasa de Falsos Positivos en IPS/WAF (TFP)	11
6.7. 7. Porcentaje de Tráfico Interno Encriptado (PTE)	12
6.8. 8. Tiempo de Respuesta a Crisis en Planta (MTTR)	12
6.9. 9. Índice de Rotación de Contraseñas Privilegiadas (IRCP)	13
6.10. 10. Cantidad de Vulnerabilidades Abiertas por Nivel (CVA)	13
6.11. 11. Cumplimiento de Privacidad de Diseñadores B2C (CAA)	14
7. Análisis Forense, Proyección Financiera y Gestión de Activos	14
7.1. Análisis Financiero: Adquisición, Mantenimiento y Riesgos	14
7.2. Evolución Operativa bajo Estrés de Black Friday	15
8. Conclusiones	16
Referencias Bibliográficas	16

1 Introducción y Análisis de la Transformación Digital

En la industria de la manufactura textil y publicitaria, la barrera tecnológica históricamente residió en las limitaciones mecánicas y químicas. Sweet Tees & more, fundada en el año 2000 en la ciudad de Lakeland, Florida, es un caso de estudio paradigmático sobre cómo la modernización de hardware de producción obliga, irremediablemente, a la sofisticación de la infraestructura de telecomunicaciones y el gobierno de bases de datos.

Durante años, la compañía dependió de la serigrafía tradicional, un modelo estático y fuertemente atado a volúmenes mínimos de producción (12 piezas). Al modernizar sus operaciones adquiriendo tecnología avanzada de impresión digital por transferencia con tóner blanco (específicamente sistemas de grado industrial como la OKI Pro9541WT), Sweet Tees & more desbloqueó la capacidad comercial de imprimir prendas de manera individual (B2C), bajo demanda y sin exigencias de compras mínimas.

Sin embargo, para poder recibir, catalogar, almacenar y procesar miles de pequeños pedidos individuales de diseñadores y usuarios finales a través de internet, fue ineludible migrar hacia un sistema e-commerce de alto flujo transaccional. La consecuencia directa de esta evolución tecnológica fue que Sweet Tees & more pasaron de ser simplemente una «empresa que fabrica camisetas» a ser una «empresa que maneja datos». Al centralizar la información crediticia (datos bancarios PII), métricas de comportamiento de usuarios y la propiedad intelectual de cientos de diseñadores (archivos vectoriales e imágenes de alta resolución), la superficie de ataque cibernético mutó drásticamente. Lo que antes podía ser un robo físico de una memoria USB, hoy representa vectores de Inyección SQL, Ransomware en la capa de endpoints, escalamiento de privilegios y colapsos perimetrales por ataques de denegación de servicio distribuido (DDoS).

2 Arquitectura de Hardware y Red (Ecosistema Híbrido)

Para proteger los sistemas, sugiero modelar la seguridad perimetral e interna bajo el concepto de defensa en profundidad. La base de operaciones tecnológicas en Lakeland depende tanto de equipamiento On-Premise como de enlaces robustos hacia la nube para interactuar con su base de datos externa.

2.1 Perímetro y Core Networking

La barrera primaria de red local (LAN) está administrada mediante dispositivos de grado empresarial. Propongo utilizar dos firewalls de Firewalls de Próxima Generación **Fortinet FortiGate 100F** en configuración Activo-Pasivo. Estos equipos no solo gestionan el enrutamiento y las reglas clásicas de puertos (Capa 3 y 4 del modelo OSI), sino que realizan Inspección Profunda de Paquetes (DPI), descifrado SSL y escaneo de malware en tránsito. El FortiGate asume también el rol de Gateway SD-WAN (Software-Defined Wide Area Network), balanceando de manera inteligente un enlace de fibra óptica dedicado de 1 Gbps provisto por AT&T con un failover automático hacia una conexión corporativa celular 5G (Verizon).

En la capa de distribución y acceso, recomiendo usar switches gestionables de la línea **Cisco Catalyst 9200L** con capacidad Power over Ethernet (PoE+). La segmentación mediante Redes de Área Local Virtual (VLAN) es rigurosa, aislando los recursos bajo la norma IEEE 802.1Q:

- **VLAN 10 (Management/Servidores):** Exclusiva para la administración de infraestructura.
- **VLAN 20 (Producción/Impresión):** Aísla las terminales industriales OKI Pro9541WT, minimizando su exposición a redes de navegación públicas.
- **VLAN 30 (Administración y Ventas):** Conecta el área de contabilidad y los endpoints de gestión.

- **VLAN 40 (Demilitarized Zone - DMZ):** Para servicios y portales que deban ser expuestos limitadamente a clientes locales.

2.2 Infraestructura de Endpoints y Servidores Locales

Para sostener la renderización gráfica previa a la impresión y gestionar perfiles de usuarios de Active Directory, Sweet Tees & more dispone en sitio de un enjambre de dos (2) Servidores **Dell PowerEdge R750**. Estos hospedan bajo virtualización (VMware ESXi) el controlador de dominio de Windows Server 2022 y el servidor central de validación de impresiones de la empresa.

Los operadores humanos y diseñadores interactúan a través de estaciones de trabajo avanzadas (**HP Z2 Tower G9 Workstations**), dotadas de tarjetas gráficas especializadas e integradas en un dominio corporativo que restringe severamente la instalación de software no autorizado, ejecución de macros ofimáticas y la conexión de almacenamiento extraíble (USB), reduciendo así la probabilidad de propagación de un *CryptoLocker* por ingeniería social.

3 Ecosistema de Bases de Datos y Nube (Cloud Storage)

El motor transaccional de toda la organización —el corazón donde fluyen pedidos y dólares— reside fuera de las premisas físicas de Lakeland. Para eludir el riesgo de desastres físicos locales (huracanes o incendios), propongo que la base de datos funcione en una infraestructura basada íntegramente en la nube de Amazon Web Services (AWS).

3.1 Sistema Gestor de Base de Datos (SGBD)

La información relacional de clientes, catálogos de prendas, órdenes de servicio, registros financieros y bitácoras de envíos operan sobre **PostgreSQL 15**. Esta base de datos se ejecuta sobre la plataforma **Amazon RDS** (Relational Database Service) configurada en modelo Multi-AZ. Esto significa que cada transacción es replicada sincrónicamente hacia un centro de datos geográficamente distante; en caso de que el nodo principal falle por un colapso de hardware o un parche defectuoso de AWS, la instancia «standby» toma el control en menos de 60 segundos sin requerir intervención humana, y sin perder un solo registro de venta de camisetas.

La base de datos se rige por un cifrado en reposo riguroso (AES-256) custodiado a través del servicio de administración de llaves maestras de AWS (KMS), con rotación automatizada cada 90 días, acatando de manera irrestricta los lineamientos legales de la industria de tarjetas de pago (PCI-DSS).

3.2 Almacenamiento de Archivos e Inmutabilidad

Los recursos gráficos de los usuarios (.PNG, .TIFF, .PDF, .AI) superan frecuentemente los 100 Megabytes por diseño. Sobrecargar una base de datos relacional (como PostgreSQL) con registros binarios (BLOBs) provocaría el colapso inmediato en su rendimiento. Por esta razón técnica, el portal web inyecta el diseño gráfico directamente en el repositorio de **Amazon S3** (Simple Storage Service) y guarda únicamente la *ruta URL* y un *hash de integridad* dentro del PostgreSQL.

Como directriz de ciberseguridad, los depósitos en Amazon S3 cuentan con reglas de inmutabilidad (**S3 Object Lock**). Esta tecnología impide técnica y administrativamente que cualquier entidad, incluso los propios programadores de la empresa o un ransomware que haya conseguido elevar privilegios, sobrescriba, encripte o elimine permanentemente los diseños de los clientes durante un periodo mínimo de resguardo (retención obligatoria de 30 días).

4 Gobernanza de Seguridad: Modelos de Acceso y SOC

El hardware y el software representan paredes estáticas; la ciberseguridad operativa exige componentes orgánicos que gestionen crisis en tiempo real. Para ello, el modelo corporativo de Sweet Tees & more se bifurca en un organigrama claro que separa los problemas mundanos de los incidentes catastróficos.

4.1 Organigrama Operativo y Roles Clave

He estructurado el equipo técnico en 12 roles clave críticos, cada uno con responsabilidades directas sobre los indicadores de gestión y la protección de los datos. Si el monitoreo falla, no es «una falla de sistema global», es la omisión de un responsable con nombre y apellido:

- **Sarah Jenkins (CEO/Gerente General):** Responsable final de la aprobación de presupuestos de licenciamiento (Fortinet, AWS). Asume las consecuencias legales si los PII de clientes son expuestos.
- **Marcus Vance (CISO):** Lidera la estrategia de ciberseguridad de la empresa. Responsable directo de vigilar el índice de rotación de contraseñas de todos los ingenieros (IRCP) y las auditorías de vulnerabilidades (CVA).
- **Elena Rodríguez (DBA Admin):** Arquitecta líder de AWS RDS. Vigila la disponibilidad del catálogo de PostgreSQL y es garante del éxito de los respaldos de la compañía (PERC).
- **David Chen (Analista SOC Senior):** Lidera el equipo MSSP externo. Monitorea los ataques de denegación contra el e-commerce (TIAF) y afina las firmas del Firewall para que los diseñadores no sufran de bloqueos por falsos positivos (TFP).
- **Michael O'Connor (Gerente de Planta Lakeland):** Coordina el flujo de los operarios para que la producción física en las OKI Pro9541WT no sufra retrasos por caídas de red.
- **Sophie Laurent (Líder de Privacidad):** Vigila bajo la norma PCI-DSS que las tarjetas de crédito de los clientes que compran camisetas no sean vulneradas, auditando todos los accesos a datos financieros (CAA).
- **Tyler Smith (Arquitecto de Red):** Mantiene las VLANs y túneles SD-WAN operacionales. Es medido por el porcentaje de tráfico encriptado de la empresa (PTE) y la estabilidad de las líneas de producción (Uptime).
- **Rachel Kim (Analista DLP):** Supervisa las alertas de prevención de pérdida de datos. Su misión es evitar que un infiltrado o empleado desleal descargue el catálogo de diseños vectoriales (IAED).
- **Lucas Mendes (Especialista On-Premise):** Encargado de los servidores Windows y VMWare en Lakeland. Su bono anual depende de la velocidad de instalación de parches críticos (TMIP).
- **James «Jim» Miller & Amanda Bates (Helpdesk Nivel 1):** Técnicos locales. Si una impresora industrial pierde conexión IP, su eficiencia en reestablecer el servicio determina el tiempo medio de resolución (MTTR).
- **Carlos Gómez (Operador OKI Pro9541WT):** Representa a los usuarios finales en planta que interactúan con el portal de producción estrictamente en modo lectura.

4.2 El Factor Humano: Centro de Soporte y Respuesta

- **Helpdesk Interno (Nivel 1):** Una cuadrilla local de analistas de infraestructura. Solucionan atascos en la flota OKI Pro9541WT, gestionan resets de credenciales de Active Directory, enrolan equipos nuevos bajo el Mobile Device Management (MDM) de Intune y reemplazan hardware defectuoso en Lakeland.
- **Centro de Operaciones de Seguridad (Nivel 2/SOC - MSSP):** Al reconocer que la ciberseguridad exige vigilancia continua que la empresa no puede absorber económicamente de forma interna, los logs provenientes de PostgreSQL, AWS y los FortiGate se canalizan hacia un servicio externo gestionado (MSSP). Este equipo opera un sistema centralizado de gestión de eventos (SIEM como Splunk o Datadog), detectando patrones de fuerza bruta o de sustracción de datos a altas horas de la madrugada.

4.3 Control de Acceso Basado en Roles (RBAC)

En un entorno de transferencia digital e-commerce de alto flujo, otorgar privilegios masivos es sinónimo de negligencia técnica. Las políticas de acceso al motor relacional son granulares y restrictivas, basándose en la primacía del menor privilegio posible.

1. **Rol de Administrador Global (DBA):** Solo puede ser asumido a través de una conexión túnel IPsec fuertemente autenticada, que requiere poseer una llave física USB U2F (YubiKey). Accede a esquemas de definición de datos (DDL) como **DROP**, **ALTER** y **TRUNCATE**.
2. **Rol de Servicio de Aplicación Web (App_ECommerce):** El portal web emplea un usuario que tiene denegada toda potestad para borrar registros. Está acotado matemáticamente para poder ejecutar exclusivamente sentencias de tipo **SELECT**, **INSERT** y en un grado supervisado **UPDATE** sobre la tabla de órdenes, bloqueando de raíz posibles fallos catastróficos por inyecciones SQL que intenten purgar las tablas maestras.
3. **Rol Operativo de Producción (Planta Lakeland):** El operador de la máquina estamadora de transferencia de tóner posee acceso de lectura (*Read-Only*). No requiere conocer el domicilio, el teléfono móvil ni los dígitos de la tarjeta de crédito del consumidor; únicamente recibe el ID del pedido, el enlace de descarga del recurso de Amazon S3, el número de prendas y la especificación de color.

5 Catálogo Exhaustivo de Evaluación de Riesgos

Todo ecosistema requiere ser escaneado con anticipación en función de vectores de amenaza inminentes. A continuación presento la tabla de riesgos que elaboré para identificar las amenazas y las posturas de mitigación por la corporación.

Elemento Físico / Lógico	Amenaza Principal	Análisis de Severidad e Impacto	Medidas Defensivas Implementadas
Base de Datos (AWS RDS PostgreSQL)	Inyección SQL o Exfiltración Masiva (Data Dump).	CRÍTICA. Compromete los datos de pago y ubicación de miles de clientes finales. Resulta en acciones penales por perjuicio de confidencialidad y ruina corporativa.	Prev: Aplicación Web Firewall (WAF) y uso estricto de <i>Prepared Statements</i> . Det: Monitoreo por SIEM SOC. Corr: Rotación de llaves AES.
Perímetro de Red (Fortinet FortiGate)	Explotación de firmware o Saturación DDoS.	ALTA. Al claudicar el firewall, la planta física en Lakeland pierde conexión con el repositorio en AWS, deteniendo el 100 % de la producción.	Prev: Suscripción Anti-DDoS y aplicación forzosa de parches de firmware en ventanas de la madrugada.
Endpoints Locales (HP Z2 Towers)	Ransomware y Gusanos Informáticos.	ALTA. Si un analista ejecuta un archivo PDF malicioso incrustado, el ransomware intentará cifrar toda unidad de red local adyacente usando Windows SMB.	Prev: Plataforma EDR de Next-Gen Antivirus (ej. CrowdStrike). Det: Monitoreo de actividad anómala de disco. Corr: Aislamiento en cuarentena de red de la MAC infectada.
Maquinaria de Manufactura (OKI)	Intercepción LAN de tramas de red (Man-in-the-Middle).	MEDIA. Competidores infiltrados de manera local capturando trabajos de arte digital que transitan por la red para apropiarse intelectualmente de los mismos.	Prev: Segmentación en VLAN estricta. Ningún PC fuera de Producción puede rutar tráfico hacia la VLAN 20 de la impresora.
Bodega Digital de Arte (Amazon S3)	Eliminación Malintencionada por ex-empleado o intruso.	ALTA. Pérdida irreparable del histórico y legado de trabajos vectoriales enviados por los diseñadores clientes a lo largo de los años.	Prev: Políticas IAM bloqueando los privilegios <code>s3:DeleteObject</code> . Activación de inmutabilidad S3 Object Lock.

Tabla 1: Matriz de catalogación y estratificación del riesgo operativo y tecnológico corporativo.

6 Libro Maestro de Indicadores de Gestión Tecnológica

Para asegurar que todo el esquema propuesto funcione, estructuré 11 indicadores de gestión que medirán el desempeño y proporcionarán inteligencia métrica; cada uno debe calcularse matemática y automáticamente mediante el NMS y los scripts periódicos en la base de datos.

6.1 1. Tasa de Intentos de Acceso Fallidos al E-Commerce (TIAF)

- **Responsable del indicador:** David Chen (Analista SOC Senior).
- **Fórmula del indicador:** $\left(\frac{\text{Intentos fallidos al portal web y base PostgreSQL}}{\text{Total de intentos de conexión hacia Sweet Tees}} \right) \times 100$
- **Utilidad del indicador:** Detecta agresiones de fuerza bruta y *Credential Stuffing* contra el portal.
- **Frecuencia de medición:** Tiempo Real (Alertamiento inmediato).
- **Unidades:** Porcentaje (%).
- **Meta:** 0 % de intrusiones exitosas.
- **Límite satisfactorio:** < 1 %.
- **Límite insatisfactorio:** > 3 % (Activa bloqueos restrictivos).
- **Valor e Importancia:** Fundamental para evitar el robo de cuentas y billeteras virtuales de los diseñadores B2C.
- **Evaluación de la presión operativa:** Presión Alta para el SOC durante eventos comerciales, donde los atacantes camuflan ejércitos de *bots* entre el tráfico de compradores legítimos.
- **Análisis del comportamiento y acciones de mejora:** David Chen emplea alertas de Splunk para banear IPs agresoras. Como mejora permanente, se recomienda integrar un sistema de CAPTCHA invisible y Autenticación Multifactor (MFA) para mitigar automatizaciones masivas.

6.2 2. Porcentaje de Éxito en Respaldos del Catálogo (PERC)

- **Responsable del indicador:** Elena Rodríguez (DBA Admin).
- **Fórmula del indicador:** $\left(\frac{\text{Respaldos de Amazon S3 y RDS completados sin error}}{\text{Total de rutinas de respaldo dictadas para la tienda}} \right) \times 100$
- **Utilidad del indicador:** Garantizar la resiliencia del negocio frente a pérdida de datos por desastres físicos o lógicos (Ransomware).
- **Frecuencia de medición:** Semanal (con pruebas trimestrales de restauración «Disaster Recovery»).
- **Unidades:** Porcentaje (%).
- **Meta:** 100 % de respaldos íntegros.
- **Límite satisfactorio:** 100 %.
- **Límite insatisfactorio:** < 100 % (Es inaceptable perder un solo snapshot de venta).
- **Valor e Importancia:** Supervivencia corporativa. El historial de ventas y los artes en formato .AI son el núcleo de Sweet Tees.

- **Evaluación de la presión operativa:** Presión Moderada. Genera carga técnica sobre Elena al tener que levantar servidores clonados para confirmar que la extracción no tenga fallos de corrupción.
- **Análisis del comportamiento y acciones de mejora:** Si un backup de base de datos falla al restaurarse, el RPO (Recovery Point Objective) pactado es nulo. Como mejora, se automatizarán las pruebas de integridad usando rutinas *Serverless* con AWS Lambda.

6.3 3. Alertas de Robo de Propiedad Intelectual (IAED)

- **Responsable del indicador:** Rachel Kim (Analista DLP).
- **Fórmula del indicador:** $\left(\frac{\text{Descargas masivas de Amazon S3 o tablas de clientes}}{\text{Consultas operativas de rutina en planta Lakeland}} \right) \times 1000$
- **Utilidad del indicador:** Detectar la exfiltración o «Scraping» masivo del catálogo de productos y diseños por parte de intrusos o deslealtad interna.
- **Frecuencia de medición:** Continua.
- **Unidades:** Permil (‰).
- **Meta:** 0‰ (Ninguna descarga anómala).
- **Límite satisfactorio:** 0‰.
- **Límite insatisfactorio:** > 1‰ (Bloqueo automático de la cuenta bajo sospecha).
- **Valor e Importancia:** Protege la ventaja competitiva comercial, evitando que otras empresas rivales inunden el mercado con los vectores gráficos de Sweet Tees.
- **Evaluación de la presión operativa:** Presión Baja a Media. El sistema actúa con Inteligencia Artificial, delegando alertas a Rachel solo ante desvíos estadísticos marcados en el comportamiento del usuario.
- **Análisis del comportamiento y acciones de mejora:** Si un operario imprime 30 playeras por hora, descargar 5,000 vectores es un fraude y alerta al DLP. Se mejorará el sistema aplicando límites duros de descarga (*Rate-Limiting*) directamente en la API de la intranet.

6.4 4. Tiempo Medio de Instalación de Parches (TMIP)

- **Responsable del indicador:** Lucas Mendes (Especialista On-Premise).
- **Fórmula del indicador:** $\frac{\Sigma(\text{Días entre la liberación de un CVE y el parcheo efectivo})}{\text{Total de actualizaciones críticas de seguridad aplicadas}}$
- **Utilidad del indicador:** Medir la agilidad con la que infraestructura cierra vulnerabilidades recién descubiertas por la comunidad.
- **Frecuencia de medición:** Mensual.
- **Unidades:** Días hábiles.
- **Meta:** 0 a 2 días hábiles para vulnerabilidades Zero-Day.
- **Límite satisfactorio:** ≤ 5 días hábiles.
- **Límite insatisfactorio:** > 7 días hábiles.
- **Valor e Importancia:** Mitigación preventiva pura. Evita que herramientas automáticas abusen de exploits públicos atacando los Fortinet o servidores Windows de la sede principal.

- **Evaluación de la presión operativa:** Presión Alta durante ventanas de mantenimiento de madrugada, afectando el ciclo de descanso del especialista de sistemas.
- **Análisis del comportamiento y acciones de mejora:** Excesivo tiempo indica que la burocracia impide apagar servidores. Como acción correctiva, se establecerá un comité de parcheo dinámico e instalación automática en terminales no críticas (WSUS) para aliviar a Lucas Mendes.

6.5 5. Disponibilidad del Sistema y Enlaces Concurrentes (Uptime)

- **Responsable del indicador:** Tyler Smith (Arquitecto de Red).
- **Fórmula del indicador:**
$$\left(\frac{\text{Tiempo total del mes} - \text{Tiempo de inactividad de VPN y AWS}}{\text{Tiempo total del mes}} \right) \times 100$$
- **Utilidad del indicador:** Certificar la continuity operativa absoluta. Mide la accesibilidad de las impresoras OKI industriales hacia la base de datos externa.
- **Frecuencia de medición:** Continua (Sondeos ICMP/TCP automatizados).
- **Unidades:** Porcentaje (%).
- **Meta:** 99,99 % (La regla de los «Cuatro nueves»).
- **Límite satisfactorio:** $\geq 99,9 \%$.
- **Límite insatisfactorio:** $< 98 \%$ (Estado de calamidad de producción).
- **Valor e Importancia:** Directamente ligado a la rentabilidad operativa. Sin conexión al RDS de la nube, la planta Lakeland no puede facturar, enviar correos ni imprimir prendas.
- **Evaluación de la presión operativa:** Presión Alta y reactiva ante fallas de fuerza mayor del proveedor de internet de fibra óptica (ISP).
- **Análisis del comportamiento y acciones de mejora:** Justifica financieramente el canal celular 5G redundante (Failover). La acción de mejora es afinar el SD-WAN en el FortiGate para que migre el tráfico de base de datos antes de que los operarios sufran desconexiones visibles.

6.6 6. Tasa de Falsos Positivos en IPS/WAF (TFP)

- **Responsable del indicador:** David Chen (Analista SOC Senior).
- **Fórmula del indicador:**
$$\left(\frac{\text{Conteo de bloqueos erróneos a usuarios lícitos}}{\text{Total de eventos de bloqueo absolutos del IPS}} \right) \times 100$$
- **Utilidad del indicador:** Balancear la seguridad y el negocio, evitando que las firmas de seguridad paralicen el flujo de clientes o diseñadores reales.
- **Frecuencia de medición:** Quincenal.
- **Unidades:** Porcentaje (%).
- **Meta:** $< 1 \%$.
- **Límite satisfactorio:** $< 5 \%$.
- **Límite insatisfactorio:** $> 10 \%$.
- **Valor e Importancia:** Evita la interrupción de ventas masivas. Un Firewall mal configurado puede dañar más las ganancias que un ciberataque.

- **Evaluación de la presión operativa:** Presión Moderada. Requiere análisis manual forense paciente sobre los paquetes IP que han sido bloqueados para justificar excepciones.
- **Análisis del comportamiento y acciones de mejora:** El SOC debe auditar registros para sintonizar («Tuning») firmas intrusivas. Ejemplo: Evitar que caracteres inusuales en vectores .AI subidos por ilustradores se interpreten como inyecciones maliciosas.

6.7 7. Porcentaje de Tráfico Interno Encriptado (PTE)

- **Responsable del indicador:** Tyler Smith (Arquitecto de Red).
- **Fórmula del indicador:** $\left(\frac{\text{Datagramas sobre protocolos TLS/IPsec LAN y WAN}}{\text{Total de tráfico auditado en la red interna de la planta}} \right) \times 100$
- **Utilidad del indicador:** Evitar la interceptación en tránsito (*Man-in-the-Middle*) y el robo de sesiones en la planta.
- **Frecuencia de medición:** Mensual.
- **Unidades:** Porcentaje (%).
- **Meta:** 100 %.
- **Límite satisfactorio:** 100 %.
- **Límite insatisfactorio:** < 100 % (Cualquier indicio de FTP, Telnet o HTTP plano está prohibido).
- **Valor e Importancia:** Resguarda el perímetro físico; si un invitado malintencionado se conecta al cableado o Wi-Fi local, no podrá interceptar datos legibles mediante rastreadores (Sniffers).
- **Evaluación de la presión operativa:** Presión Baja, tras una correcta consolidación de la Infraestructura de Clave Pública (PKI).
- **Análisis del comportamiento y acciones de mejora:** Algunos conectores de impresoras industriales pueden usar HTTP por defecto. La acción de remediación dictamina crear VLANs exclusivas aisladas si dichas impresoras no soportan encriptación de fábrica.

6.8 8. Tiempo de Respuesta a Crisis en Planta (MTTR)

- **Responsable del indicador:** Jim Miller & Amanda Bates (Helpdesk Nivel 1).
- **Fórmula del indicador:** $\frac{\Sigma(\text{Tiempos de maquinaria OKI inoperativa sin conexión al servidor})}{\text{Total de incidentes Grado 1 (Desconexión de Planta)}}$
- **Utilidad del indicador:** Medir la madurez operativa y la agilidad de recuperación de la cuadrilla técnica ante fallas in-situ.
- **Frecuencia de medición:** Trimestral.
- **Unidades:** Minutos u Horas.
- **Meta:** < 15 minutos por cada fallo catastrófico.
- **Límite satisfactorio:** ≤ 30 minutos.
- **Límite insatisfactorio:** > 60 minutos (Se incursiona en daños financieros corporativos).
- **Valor e Importancia:** Evita pérdidas exorbitantes por lucro cesante. Como estipula la matriz financiera, mantener la imprenta caída supone pérdidas calculables de \$5,000 USD diarios.

- **Evaluación de la presión operativa:** Presión Extrema. Los técnicos de hardware deben resolver bloqueos y reemplazos físicos corriendo bajo la mirada ansiosa de la gerencia de planta y operadores cruzados de brazos.
- **Análisis del comportamiento y acciones de mejora:** MTTR de varias horas indican técnicos improvisando soluciones. La mejora será redactar *Playbooks* estandarizados para reiniciar switches en menos de tres clics y acopiar fuentes de poder de repuesto en los armarios de telecomunicaciones (Stock in-situ).

6.9 9. Índice de Rotación de Contraseñas Privilegiadas (IRCP)

- **Responsable del indicador:** Marcus Vance (CISO).
- **Fórmula del indicador:**
$$\left(\frac{\text{Cuentas Root, Dominio y DBA con clave reseteada a tiempo}}{\text{Totalidad de cuentas clasificadas como de alto privilegio}} \right) \times 100$$
- **Utilidad del indicador:** Prevenir secuestros corporativos derivados de llaves maestras estáticas y legadas.
- **Frecuencia de medición:** Trimestral.
- **Unidades:** Porcentaje (%).
- **Meta:** 100 %.
- **Límite satisfactorio:** 100 %.
- **Límite insatisfactorio:** < 100 % (Representa un vector de intrusión inminente).
- **Valor e Importancia:** Elimina el riesgo subyacente de exempleados enojados o proveedores tercerizados que retienen acceso a los sistemas núcleo (AWS y VMware).
- **Evaluación de la presión operativa:** Presión Baja, asumiendo una automatización madura mediante software PAM (*Privileged Access Management*).
- **Análisis del comportamiento y acciones de mejora:** Las políticas manuales suelen fallar por olvido humano. La recomendación es orquestar una herramienta que, cada 90 días exactos, aleatorice la contraseña de `administrator` y `postgres` inyectándolas en las aplicaciones, garantizando que nadie sepa la clave real.

6.10 10. Cantidad de Vulnerabilidades Abiertas por Nivel (CVA)

- **Responsable del indicador:** Marcus Vance (CISO) y Auditoría Ofensiva.
- **Fórmula del indicador:** Conteo estadístico y suma directa de brechas reportadas mediante escaneos dinámicos de caja negra y blanca (Ej. Tenable Nessus).
- **Utilidad del indicador:** Fotografía y termómetro de la Deuda Técnica que alberga Sweet Tees & more.
- **Frecuencia de medición:** Continua.
- **Unidades:** Conteo de valores numéricos absolutos.
- **Meta:** 0 hallazgos catalogados en franja Crítica / Alta.
- **Límite satisfactorio:** Solo fallos catalogados como «Informacionales» o «Bajos» bajo aceptación de riesgo documentada.
- **Límite insatisfactorio:** > 0 vulnerabilidades de grado Crítico presentes en el portal B2C o Firewall perimetral.

- **Valor e Importancia:** Indicador proactivo; evita que un hacker escale privilegios internamente antes de que este indicador lo revele.
- **Evaluación de la presión operativa:** Presión Alta a nivel organizacional. Obliga a pelear por ventanas de desconexión de servicios con otras áreas gerenciales de negocios.
- **Análisis del comportamiento y acciones de mejora:** Si gerencia objeta corregir brechas por miedo a reiniciar AWS, la postura se deteriora. Como medida correctiva, se usará *Virtual Patching* en el WAF (mitigación superficial) en lo que las ventanas físicas se autorizan administrativamente.

6.11 11. Cumplimiento de Privacidad de Diseñadores B2C (CAA)

- **Responsable del indicador:** Sophie Laurent (Líder de Privacidad).
- **Fórmula del indicador:**
$$\left(\frac{\text{Accesos justificados a la tabla de facturación financiera o datos PII}}{\text{Total de consultas realizadas a registros financieros SQL}} \right) \times 100$$
- **Utilidad del indicador:** Extirpar la cultura del «Snooping» (espionaje interno malicioso) y justificar auditorías externas PCI-DSS.
- **Frecuencia de medición:** Semestral.
- **Unidades:** Porcentaje (%).
- **Meta:** 100 %.
- **Límite satisfactorio:** 100 %.
- **Límite insatisfactorio:** < 100 % (Detona investigación de Recursos Humanos y suspensión).
- **Valor e Importancia:** Asegura la honorabilidad corporativa y previene costosas demandas colectivas por violación a regulaciones de retención de pagos electrónicos.
- **Evaluación de la presión operativa:** Presión Alta y restrictiva a nivel de burocracia administrativa. Exige justificar cada acceso de manera individualizada.
- **Análisis del comportamiento y acciones de mejora:** Los operarios y técnicos de sistema gozan de grandes permisos y sienten curiosidad por las bases de datos de clientes y corporativos de renombre. Para asegurar este cumplimiento al 100 %, se inyectará «Enmascaramiento Dinámico de Datos» directamente sobre el SGBD PostgreSQL, ocultando sistemáticamente los caracteres críticos a menos que se introduzca la ID de un ticket corporativo para desbloquear la vista SQL.

7 Análisis Forense, Proyección Financiera y Gestión de Activos

Durante el cuarto trimestre operativo (Q4), el sector comercial experimenta los picos volúmenes del *Black Friday* y *Cyber Monday*. Para la CEO Sarah Jenkins, la ciberseguridad es una inversión con retorno directo (ROI) que blindas las utilidades.

7.1 Análisis Financiero: Adquisición, Mantenimiento y Riesgos

La viabilidad operativa exigió inversiones tangibles. Las maquinarias industriales **OKI Pro9541WT** poseen un costo de adquisición superior a \$10,000 USD por unidad. A su vez, los clústeres de firewall **Fortinet 100F** demandaron \$2,500 USD en hardware más \$1,800 USD en licenciamientos anuales UTP. La arquitectura **AWS RDS Multi-AZ** de PostgreSQL representa un gasto corriente (OPEX) aproximado de \$850 USD al mes por otorgar alta disponibilidad.

Los riesgos de omitir el mantenimiento preventivo, renovar garantías o escatimar en dichas licencias son desastrosos. Si Sarah Jenkins recorta el pago del mantenimiento de Fortinet, el SOC de David Chen pierde el motor *Anti-DDoS* y los parches Zero-Day. Bajo ese escenario de negligencia gerencial, un ataque exitoso de *Ransomware* no solo paralizaría las OKI (infligiendo un costo de lucro cesante de \$5,000 USD diarios por no poder procesar camisas), sino que sometería a la compañía a demandas colectivas millonarias por violación a la normativa PCI-DSS al exponer datos financieros desprotegidos.

7.2 Evolución Operativa bajo Estrés de Black Friday

Las tablas a continuación documentan el fenómeno y la resolución técnica derivada del monitoreo férreo a los indicadores operados por la nueva plantilla de ingenieros:

Indicador Crítico	Oct	Nov	Dic	Reporte Ejecutivo y Resolución Tecnológica
1. TIAF (Ataques Fuerza Bruta)	1.2 %	11.5 %	0.8 %	Durante el pico de ventas (Nov), enjambres automáticos perpetraron <i>Credential Stuffing</i> contra el portal API web. Para Diciembre, la intervención activó reglas estrictas de WAF, implementando <i>*Rate Limiting*</i> (Topes transaccionales) y listas negras dinámicas por país de procedencia.
3. IAED (Alerta Exfiltración)	0	1.2	0	Un analista principiante disparó sin mala voluntad un vaciado absoluto de la base de clientes mediante comando export en vez de filtrar un periodo de un mes. El componente de monitorización (DLP) bloqueó su usuario provisionalmente, probando ser vital ante fugas negligentes.
5. Uptime (Estabilidad Transaccional)	99.9 %	97.1 %	99.9 %	Constituye el percance más lesivo para la reputación de la cadena comercial. El nodo principal de PostgreSQL (AWS) fue asediado en carga de transacciones y colapsó sus tablas. La mitigación inmediata forzó a los ingenieros a dividir el tráfico en Replicas de Lectura independientes.
6. TFP (Restricciones Falsas)	2.1 %	14 %	3.5 %	El Fortinet detectó la subida masiva de arte digital (.AI de ilustradores) como ataques a sistemas. Al bloquear a los diseñadores genuinos y cortar el circuito de caja, los especialistas del SOC perfilaron las firmas de seguridad, mitigando en horas el malentendido técnico.

Tabla 2: Matriz de Evolución Transaccional bajo Estrés (Q4) fundamentada en los KPIs.

8 Conclusiones

Como estudiante analizando este caso, mi conclusión es que el salto cualitativo de *Sweet Tees & more* demuestra del ecosistema comercial presente: la hiperconectividad B2C a escala global condena a la obsolescencia tanto al equipamiento de producción básico como a los esquemas de gestión informática frágiles y reactivos.

Al desplegar servidores empresariales virtualizados, enrutar tráfico cifrado mediante firewalls dedicados y resguardar en depósitos de AWS y PostgreSQL sus valiosas mercancías de arte gráfico digital, la corporación asumió conscientemente la modernidad del riesgo cibernético.

Mi propuesta con los once indicadores demuestra empíricamente que la seguridad no recae en la simpleza de instalar equipos, sino en el modelamiento de tableros y en ingenieros empoderados operando bajo normas de confianza cero (Zero Trust). Es mediante este gobierno real que se imposibilitan las tragedias reputacionales, blindando un modelo de negocio intensamente exigente.

Referencias

- [1] Amazon Web Services. (2023). *Security Best Practices for Amazon RDS PostgreSQL*. AWS Prescriptive Guidance. Recuperado de la documentación oficial de arquitectura en la nube, aplicable a la topología de almacenamiento cifrado del SGBD y la métrica de Inmutabilidad S3.
- [2] Fortinet Inc. (2023). *FortiGate Security Configuration and Best Practices for SD-WAN*. Referencia técnica base para la estructuración de defensa en profundidad y la mitigación de exfiltraciones hacia el centro de datos y endpoints locales de Lakeland.
- [3] PCI Security Standards Council. (2024). *Payment Card Industry Data Security Standard (PCI DSS) v4.0.1*. Regulaciones mandatorias adoptadas por la Líder de Privacidad para gobernar el acceso a información financieramente sensible (PII) bajo políticas de Zero Trust.
- [4] ISACA. (2019). *COBIT 2019 Framework: Governance and Management Objectives*. Empleado como marco teórico universal para estructurar el organigrama operativo (CEO, CISO, DBA, SOC) y entrelazarlos bajo la responsabilidad ineludible de los 11 indicadores tecnológicos.
- [5] International Organization for Standardization (ISO). (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems*. Eje rector para la conformación del Sistema de Gestión de Seguridad de la Información (SGSI) adoptado por Sweet Tees.
- [6] National Institute of Standards and Technology (NIST). (2020). *Integrating Cybersecurity and Enterprise Risk Management (ERM) - NISTIR 8286*. Base analítica para cuantificar las pérdidas de lucro cesante y proyección financiera (CAPEX/OPEX) del hardware de seguridad y maquinaria OKI.
- [7] Cybersecurity and Infrastructure Security Agency (CISA). (2023). *Ransomware Guide and Incident Response Playbook*. Documento rector adoptado por el SOC y el Helpdesk local para medir e impulsar el tiempo medio de recuperación ante crisis (MTTR).